

WALL MANAGEMENT SYSTEM

Production & Compliance Specification · v1.1 Consolidated

- 32 launch features across 6 pillars · production-grade engineering
- DPDP Act 2023 & Rules 2025 · GST, IT Act, RBI, consumer-protection & IP compliance
- QR-only architecture (NFC removed) · editable slots, sizes & add-on pricing
- Simple admin-set refund policy · minimal founder ledger
- Ric Platter partnership: QR scan at checkout → 10% reward + sale tracking (no POS needed)

Document	AWL/ENG/2026/WMS-SPEC-002 (v1.1 Consolidated)
Supersedes	AWL/ENG/2026/WMS-SPEC-001 & affected parts of WMS-001
Scope	32 features + 3 configurability changes + QR coupon partnership
Data Role	Artwall Labs Pvt Ltd = Data Fiduciary under DPDP Act, 2023
Classification	Internal — Engineering, Legal & Compliance
Version	1.1 · August 2026

Contents

- 1 How to read this document
- 2 Change log — what v1.1 changes
- 3 Feature lifecycles — 32 launch features
 - Pillar 1 · Slot Management (F01–F12)
 - Pillar 2 · Exhibition Operations (F13–F16)
 - Pillar 3 · Payments & Billing (F17–F20)
 - Pillar 4 · Visitor & Analytics (F21–F26)
 - Pillar 5 · Discovery & Engagement (F27–F30)
 - Pillar 6 · Artist Management (F31–F32)
- 4 Configurability changes (C01–C05, C07)
- 5 Ric Platter partnership — QR coupon reward + sale tracking (RP01)
- 6 Production-grade engineering
- 7 Security engineering & threat model
- 8 DPDP Act 2023 & Rules 2025 compliance
- 9 Other regulatory compliance
- 10 Feature × compliance traceability
- 11 Data retention & lifecycle schedule

1 How to Read This Document

Every feature is specified as a small state machine. The intent is that an engineer can implement it, a reviewer can audit it, and legal can confirm it processes personal data lawfully — from one block.

Each feature block carries:

- **Lifecycle** — the ordered states the entity moves through and who triggers each move.
- **Rules** — the invariants the system enforces.
- **Data & PII** — the tables touched and whether personal data is involved.
- **Events** — domain events emitted, driving async work (email, webhook, socket).
- **Edge / failure** — non-happy paths that must be handled for production-grade operation.
- **Compliance** — appears only where the feature touches a regulated activity.

Legend: $A \rightarrow B$ is a permitted transition; [admin] shows who may trigger it. Terminal states have no outgoing arrow.

2 Change Log — What v1.1 Changes

This consolidated document merges the original production spec (SPEC-001) with revision v1.1. The following changes are baked into the feature blocks that follow.

Ref	Change	Type	Affects
C01	Slots fully variable & editable	Config	F01, F02
C02	Slot sizes configurable (dimensions + base price)	Config	F03, pricing
C03	Add-on pricing editable (admin catalog incl. coffee)	Config	F11
C04	Full admin queue management	Enhancement	F10
C05	Admin-set refund policy (single configurable line)	Simplification	F12, F20
C06	QR-only — NFC removed entirely	Architecture	F15, F21, F22
C07	Minimal revenue & expenditure ledger	Simplification	F18, F19
RP01	Ric Platter QR coupon reward + sale tracking (scan at checkout)	Partnership	F26, F31

Removed from original v1.1 scope: Full restaurant menu integration (P01), food ordering through platform (P02), collaboration sales tracker (P03). Restaurant perks simplified to a QR coupon system (RP01).

3 Feature Lifecycles

Thirty-two launch features, grouped by six pillars. Incorporates all v1.1 configurability changes inline.

Pillar 1 · Slot Management

F01 Dynamic slot grid configuration

Admin · POST /wall/resize

ACTORS

Admin (owner), System (validation)

LIFECYCLE

draft grid → [admin] validate (no overlaps, sane bounds) → publish → active → [admin] re-config → re-validate → re-publish

RULES

Slot count is admin-set, not hard-coded. A re-config may not orphan a live booking: slots in state live/installed/booked are locked and carried across configs. Templates ('28-slot standard') are saved layouts. Admin can add, remove, resize and reposition any slot at will; layouts save as reusable templates. **[C01 applied]**

DATA & PII

slots, grid_config. No personal data.

EVENTS

grid.reconfigured → invalidates availability cache, re-renders live wall.

EDGE / FAILURE

Reducing the grid below the count of occupied slots is rejected; concurrent edits guarded by version/optimistic lock. Every structural edit is versioned and written to audit_log.

F02 Visual slot map editor (drag-and-drop)

Admin · POST /wall/reorder

ACTORS

Admin

LIFECYCLE

select slot → drag → drop on target → [system] swap grid coordinates atomically → persist

RULES

Drag swaps two slots' coordinates in a single transaction so no two slots ever share a cell. Editing is disabled for terminal/locked slots. Every move writes to audit_log. **[C01 applied]**

DATA & PII

slots.row/col. No personal data.

EVENTS

slot.moved → socket broadcast to any open editor session.

EDGE / FAILURE

Drop onto an occupied cell = swap, never overwrite; dropped-outside = no-op; last-write-wins guarded by row version.

F03 Slot size categories (configurable catalog)

ACTORS

Admin (defines catalog), Pricing engine (reads)

LIFECYCLE

admin defines size class in catalog → size feeds pricing + install checklist → size change re-prices future bookings only

RULES

Sizes are a managed catalog, not a hard-coded enum. Admin defines each class: name, physical dimensions (W×H cm), weight limit and editable base price/day. Add, rename, retire classes. Changes apply to future bookings only; a confirmed booking keeps the price it was quoted. **[C02 applied]**

DATA & PII

size_catalog {id, name, w_cm, h_cm, weight_kg, base_price, active}. No personal data.

EVENTS

slot.resized.

EDGE / FAILURE

Size change while a booking is live is queued to apply at next ended → available.

F04 Slot status lifecycle management

`POST /slots/:id/transition`

ACTORS

Artist, Staff, Admin, System (timers)

LIFECYCLE

available → reserved (hold timer) → booked (paid) → received → installed → live → ended → available · side states: maintenance, blocked, admin_hold

RULES

Only transitions in the machine are legal; illegal moves rejected with 409 server-side. reserved auto-expires back to available on hold-timer lapse. Force paths are admin-only (F12).

DATA & PII

slots.state; state changes appended to audit_log. No personal data in the state itself.

EVENTS

slot.transitioned {from, to} → drives carousel, notifications, install queue.

EDGE / FAILURE

Hold-timer expiry race resolved by DB-level guard; a stuck received raises an ops alert after SLA.

F05 Multiple slot types

ACTORS

Admin (assigns), Pricing engine (reads)

LIFECYCLE

assign type → type sets price multiplier + eligibility → Sponsored type = 0-fee, admin-granted

RULES

Type multiplier feeds pricing (Premium 1.4×, Featured 1.8×, Workshop 1.5×, Walk-in 1.3×, Sponsored 0×). Walk-in slots are held for day-of bookings; Sponsored requires an admin grant and a funding source record.

DATA & PII

slots.type enum. No personal data.

EVENTS

slot.retyped.

EDGE / FAILURE

Downgrading a Featured slot mid-booking honours the original price for that booking.

F06 Calendar-based availability view

`GET /slots/availability`

ACTORS

Artist (reads), System (computes)

LIFECYCLE

query(date-range, filters) → compute free slots (state=available AND no overlapping hold/booking) → render

RULES

Availability is read from a Redis-cached slot map (TTL 15s) with Postgres fallback. A slot is 'available' for a date only if no confirmed booking or live hold overlaps that window.

DATA & PII

slots, bookings (dates only). No personal data returned to the client.

EVENTS

none (read path).

EDGE / FAILURE

Cache miss falls back to replica; stale-read window bounded to TTL and reconciled at reservation time.

F07 Multi-slot booking

POST /bookings

ACTORS

Artist / Curator

LIFECYCLE

select N slots → reserve all (atomic, all-or-nothing) → single order → pay → all N move to booked, or all roll back

RULES

All-or-nothing: if any slot in the set cannot be held, the whole reservation fails. Group discounts apply at 5+/10+/full-wall tiers. Advisory lock per slot prevents double-booking.

DATA & PII

bookings.slot_ids[], artist_id. Personal data: links to an identified artist.

EVENTS

booking.created → invoice, agreement, confirmation graphic, socket update.

EDGE / FAILURE

Partial hold failure → full rollback + released holds; payment timeout → holds expire, slots return to available.

COMPLIANCE

DPDP (personal data), RBI/PCI (payment).

F08 Duration selection (daily to custom)

ACTORS

Artist

LIFECYCLE

pick duration → pricing engine applies per-day discount curve → sets booking end-date → schedules de-install reminder

RULES

Longer durations get lower per-day rates (1d=1.0, 3d=0.95, 1w=0.88, 2w=0.82, 1mo=0.72). End-date sets the live → ended timer and the de-install task.

DATA & PII

bookings.duration/end_date. Linked to artist.

EVENTS

booking.scheduled → de-install reminder job at end-date-24h.

EDGE / FAILURE

Custom span validated against min/max and buffer time between bookings.

F09 Artwork upload during booking

POST /artworks

ACTORS

Artist

LIFECYCLE

request presigned URL → direct upload to object store → server validates → attach to booking → artwork in draft → goes public on go-live

RULES

Uploads go direct-to-S3 via presigned URL, never through the API. Server validates MIME + magic bytes + size cap and re-encodes to strip metadata/exploits. Artist retains copyright; platform holds a display licence (see F20).

DATA & PII

artworks; image may incidentally contain EXIF/GPS — stripped on re-encode (privacy-by-design).

EVENTS

artwork.uploaded → thumbnail + search-index jobs.

EDGE / FAILURE

Disguised/oversized/non-image files rejected; failed re-encode quarantines the file and blocks publish.

COMPLIANCE

DPDP, IP / IT Act.

F10 Waitlist and queue system (full admin control)

POST /waitlist

ACTORS

Artist, Admin, System (matcher)

LIFECYCLE

join waitlist (prefs) → queued (priority-ordered) → [slot opens] matched → notified with hold → convert to booking OR expire → re-queue next. Admin can reorder, promote/demote, remove, add notes, override priority, and force-match any waitlisted artist directly. **[C04 applied]**

RULES

Priority order: Founding Members > repeat > referred > new. Manual overrides sit above automatic priority; every override is logged. Match offers a time-boxed hold; on expiry the offer passes to the next in queue.

DATA & PII

waitlist stores name + contact + prefs = personal data → consent + retention apply.

EVENTS

waitlist.matched → notification (email/WhatsApp/SMS per the artist's channel prefs).

EDGE / FAILURE

Notify-channel failure falls back to the next channel; abandoned offers auto-expire.

COMPLIANCE

DPDP (personal data).

F11 Add-on pricing system (editable admin catalog)

ACTORS

Artist, Admin, Pricing engine

LIFECYCLE

admin manages add-on catalog → artist selects add-ons at booking → priced as flat line-items → added to order total → fulfilled as tasks post-booking. [C03 applied]

RULES

Add-ons are an admin-managed catalog: label, price, who it applies to (artist/visitor/both), category (general/coffee), active flag. Prices editable any time; coffee add-ons for the Ric Platter partnership live in this same catalog. A booking locks the add-on price at purchase time. Each fulfilled add-on becomes an ops task.

DATA & PII

addon_catalog {id, label, price, applies_to, category, active}; bookings.add_ons[]. Linked to artist.

EVENTS

addon.selected → ops task creation on booking confirm.

EDGE / FAILURE

An add-on that cannot be fulfilled flags the booking and offers a refund of that line-item only.

F12 Admin force-book & force-release + configurable refund

Admin · SEC-12 audited

ACTORS

Admin only

LIFECYCLE

force-book: any → booked [admin] · force-release: any → available [admin] + refund trigger per admin-set policy. [C05 applied]

RULES

Admin-only (RBAC). Bypasses availability/payment checks by design, but every force action writes actor + before/after to audit_log. Force-release queues refund computed from the active refund policy. **Refund policy is a single admin-configured line:** the admin sets the refund percentage and it applies to all cancellations. No complex tier logic — one rule, applied uniformly. The policy version in force at booking time governs that booking's refund; the agreement (F20) embeds that version.

DATA & PII

slots, audit_log (actor = admin identity). refund_policy {percentage, version}.

EVENTS

slot.forced {action} → refund job + affected-artist notification.

EDGE / FAILURE

Force-release of a live artwork raises a de-install task and documents condition first; requires a confirm step.

Pillar 2 · Exhibition Operations

F13 Installation window scheduling

POST /checkin/*

ACTORS

Artist, Staff, System

LIFECYCLE

booking confirmed → offer windows → artist picks → window reserved → staff task created → check-in (F15)

RULES

Windows respect venue hours and buffer time between bookings. One artwork per window; overlaps blocked.

DATA & PII

install_windows linked to booking/artist.

EVENTS

install.scheduled → staff task + reminder to artist.

EDGE / FAILURE

No-show handling: missed window auto-reschedules once, then flags the booking.

F14 Pre-installation checklist generation

ACTORS

System (generates), Staff (executes)

LIFECYCLE

install scheduled → generate checklist from slot size/type + add-ons → staff ticks items → 100% required to activate

RULES

Checklist is derived, not manual: size/type/add-ons decide items (hardware, QR label, spotlight, condition photos). All items must be complete before received → installed. **[C06: NFC items removed; QR label check added]**

DATA & PII

checkins.checklist; condition photos are of artwork, not persons.

EVENTS

checklist.completed → enables go-live.

EDGE / FAILURE

Incomplete checklist blocks activation; a failed item (e.g. damaged frame) opens a condition/damage record.

F15 Staff check-in workflow with QR verification

POST /checkin/verify

ACTORS

Staff, Artist (presents QR), System

LIFECYCLE

scan booking QR → verify signature + booking match → run checklist (F14) → assign & link QR label → activate → live.
[C06: QR-only, NFC removed]

RULES

QR encodes a signed booking token, not raw personal data — verified server-side (privacy-by-design). QR label linked here connects the physical piece to its digital record; activation flips installed → live. Every QR resolves through a signed server-side redirect (short branded URL → signed token → artwork page) so a copied code still lands on the real page. Tamper-evident, branded QR labels and a staff spot-check mitigate swap risk.

DATA & PII

Verifies against bookings/artists; scan event logged. Minimal PII exposure — only booking-scoped.

EVENTS

checkin.verified, artwork.live.

EDGE / FAILURE

Invalid/expired/tampered QR rejected; mismatch (wrong artwork) blocks and alerts.

F16 Exhibition calendar (master + Gantt)

GET /calendar

ACTORS

Staff, Admin

LIFECYCLE

aggregate all bookings → render master calendar + Gantt bars → surface gaps → suggest waitlist fills

RULES

Read model over bookings + slots; gaps of 3+ days trigger auto-rotation suggestions from the waitlist.

DATA & PII

Displays artist names to staff/admin only (authorised, need-to-know).

EVENTS

none (read); acting on a suggestion creates a waitlist offer.

EDGE / FAILURE

Timezone-safe date math; overlapping bars from buffer time rendered distinctly.

Pillar 3 · Payments & Billing

F17 Razorpay integration (UPI, cards, net banking)

POST /payments/order · /webhooks/razorpay

ACTORS

Artist (pays), Razorpay (PSP), System

LIFECYCLE

create order → artist pays (UPI/card/netbanking) → Razorpay webhook (HMAC-verified) → mark paid in a DB txn → booking booked

RULES

A booking is marked paid ONLY on a signature-verified webhook, never a client callback. Card data never touches our servers — Razorpay is PCI-DSS scoped; we store no PAN. Tokenisation per RBI card-storage norms handled by the PSP.

DATA & PII

payments stores order/txn refs + amount, not card data. Linked to artist.

EVENTS

payment.captured → invoice PDF, confirmation, socket, ledger entry (C07).

EDGE / FAILURE

Webhook idempotency by event id; late/duplicate webhooks ignored; failed payment leaves booking unpaid and holds expire.

COMPLIANCE

DPDP, RBI/PCI, GST/tax.

F18 Revenue & expenditure ledger (minimal)

GET /finance/ledger

ACTORS

Admin / Founder

LIFECYCLE

record revenue entries (bookings, add-ons, coffee, sale commission) and expenditure entries (venue share, ops, misc) → category tag + date → running monthly summary → one-click CSV export for accountant. [C07: replaces auto-P&L]

RULES

A simple two-list ledger. GST invoices are still issued on transactions (unchanged). Heavy P&L modelling is deferred until volume justifies it — then integrate Tally/Zoho Books rather than hand-rolling.

DATA & PII

ledger {id, type(revenue|expense), category, amount, note, date, source_ref}. Financial aggregates; no personal data.

EVENTS

ledger.entry.created.

EDGE / FAILURE

Refunds and chargebacks net against the day they settle, not the sale day.

F19 Monthly summary export

ACTORS

Admin / Founder

LIFECYCLE

month end → aggregate ledger entries → show summary by category → CSV export

RULES

Reads from the ledger (F18). Admin-only. No locked periods — corrections are new entries with notes. GST output tax tracked separately (GSTIN 08ABFCA1595D1ZR).

DATA & PII

Financial aggregates; no personal data on the summary.

EVENTS

summary.exported.

EDGE / FAILURE

Late-settling transactions post to the open period.

F20 Digital exhibition agreement (auto-generated, e-signed)

`POST /agreements/:id`

ACTORS

System (generates), Artist (e-signs)

LIFECYCLE

booking → auto-generate agreement from template + booking facts → artist reviews → e-sign → stored immutably (hash) → accessible to both parties

RULES

Auto-populated with slots, fee, duration, GSTIN, and the admin-set refund policy version in force at booking time [C05]. E-signature valid under the IT Act, 2000 (S6). Terms cover: artist retains copyright + platform display licence; 15% sale commission; 4%+1% resale royalty (ERC-2981); insurance/liability; the single refund-policy line.

DATA & PII

agreements — artist identity + signature timestamp; immutable, hash-sealed.

EVENTS

agreement.signed → unlocks install scheduling.

EDGE / FAILURE

Unsigned agreement blocks go-live; template versioning ensures the artist signs the version shown (terms_hash).

COMPLIANCE

DPDP, RBI/PCI, GST/tax, IP / IT Act.

Pillar 4 · Visitor & Analytics

F21 QR scan tracking

POST /scan/:id

ACTORS

Visitor (anonymous), System

LIFECYCLE

visitor scans QR → resolve artwork → log scan event (async) → increment counters → open artwork page (F22). **[C06: QR-only]**

RULES

Scans are ingested asynchronously via queue, not synchronous writes, to absorb spikes. Anonymous by default — no account required; rate-limited per IP+cookie to keep the demand signal honest. Design choice: do not store raw IP against scans; use a rotating hashed key for rate-limiting only → minimises personal data.

DATA & PII

scans {artwork_id, ts, source}. Minimal personal data by design.

EVENTS

artwork.scanned → analytics + demand-signal aggregation.

EDGE / FAILURE

Duplicate rapid scans deduped in a short window; queue backpressure never blocks the page load.

COMPLIANCE

DPDP (data minimisation).

F22 Artwork page with full details

GET /artworks/:id

ACTORS

Visitor (public), Artist (subject)

LIFECYCLE

request by slug/id → server-render (ISR, SEO) → show details + actions (interest, react, share, selfie)

RULES

Public, SEO-optimised (Open Graph + Schema.org VisualArtwork), served via ISR/CDN. Artist contact is never exposed — buyer interest routes through the platform. **[C06: reached by QR only]**

DATA & PII

Shows artist public profile fields only (name, city, bio) — the artist consents to publication at registration.

EVENTS

artwork.viewed; 'interested' feeds demand-triggered sale.

EDGE / FAILURE

Ended artworks resolve to an archived page, not a 404, preserving links + SEO.

COMPLIANCE

DPDP, IP / IT Act.

F23 Social sharing (WhatsApp, Instagram, X)

ACTORS

Visitor / Artist

LIFECYCLE

tap share → pick channel → pre-filled text + OG image → posted off-platform

RULES

Client-side share intents; the shared link is the public artwork page (F22) with an OG image. No personal data leaves with the share beyond what is already public.

DATA & PII

None beyond public artwork/artist data.

EVENTS

artwork.shared {channel} → share-rate metric.

EDGE / FAILURE

Channel unavailable → copy-link fallback.

F24 Reaction system

`POST /artworks/:id/react`

ACTORS

Visitor (anonymous)

LIFECYCLE

tap reaction → increment aggregate → optimistic UI update

RULES

No account needed; rate-limited per IP+cookie. Stored as aggregate counts, not per-person rows → inherently low-PII.

DATA & PII

reactions aggregate counts. No personal data.

EVENTS

artwork reacted {kind}.

EDGE / FAILURE

Spam/bot bursts throttled and dampened before they reach aggregates.

F25 Selfie upload with branded frame

Consent-gated · POST /ugc

ACTORS

Visitor, Moderator (staff/admin)

LIFECYCLE

capture/upload → apply branded frame → submit → pending moderation → approved → community gallery (F30) OR rejected

RULES

A selfie is a photograph of an identifiable person = personal data → explicit, informed consent captured at upload for public display, with a clear withdrawal path. Images validated + re-encoded. If the person may be a minor, publication requires verifiable parental consent.

DATA & PII

ugc — image of a person + optional caption. High-sensitivity; consent-gated.

EVENTS

ugc.submitted → moderation queue.

EDGE / FAILURE

Rejected/withdrawn UGC is deleted from gallery + CDN cache purged.

COMPLIANCE

DPDP (consent, children's data), IP / IT Act.

F26 Walk-in visitor registration + reward QR

Consent-first · POST /visitors

ACTORS

Visitor

LIFECYCLE

register (name + phone/email + consent) → session links subsequent scans → **visitor receives a personal QR code** → post-visit summary email → retained per schedule. **[RP01: QR scanned at Ric Platter counter while checking out — applies 10% reward AND captures bill amount as a sale record]**

RULES

Collection is consent-first: purpose (visit summary + optional future invites + restaurant reward) stated at the point of collection; marketing consent is a separate opt-in, not bundled. Minimal fields only. The personal QR is the visitor's coupon — they present it at the Ric Platter counter at checkout. Staff scans it and enters the bill total. The system applies 10% off and logs the bill amount as an attributed sale, linking it to the artworks the visitor scanned during their visit. One redemption per visit, time-boxed.

DATA & PII

visitors — name + contact = personal data. Consent + retention + rights apply. perk_redemptions {id, principal_type, principal_id, bill_amount, discount_amount, artwork_ref, visit_ref, redeemed_at}.

EVENTS

visitor.registered → summary email job. perk.redeemed → sale attributed + ledger entry.

EDGE / FAILURE

No consent = no registration; contact validation before store. Perk abuse controls: one active perk per visit, time-boxed, not stackable unless admin opts in.

COMPLIANCE

DPDP (personal data, consent).

Pillar 5 · Discovery & Engagement

F27 Live carousel on artwalllabs.com

GET /slots + WS

ACTORS

Visitor (public), System

LIFECYCLE

artwork goes live → appears in carousel → artwork ends → removed → real-time via socket

RULES

Driven by slot.transitioned events over Socket.IO + Redis fan-out, not per-client polling. Shows only public data.

DATA & PII

Public artwork + artist public fields only.

EVENTS

consumes artwork.live / artwork.ended.

EDGE / FAILURE

Socket drop → client falls back to periodic REST refresh; cold load served from ISR cache.

F28 Full-text search engine

GET /search

ACTORS

Visitor (public), System

LIFECYCLE

index artworks/artists on publish → query → ranked results → filters (medium, date, price, location)

RULES

Async indexing to Meilisearch on publish; index holds only public fields. Query strings validated; no PII in query logs.

DATA & PII

Indexes public data only. Search logs avoid personal identifiers.

EVENTS

index.updated on artwork publish/unpublish.

EDGE / FAILURE

Index lag bounded; a just-published piece appears within the indexing SLA; empty results give a directed empty state.

F29 Booking confirmation shareable graphic

ACTORS

Artist, System

LIFECYCLE

booking confirmed → render branded graphic (slots, dates, venue) → artist downloads/shares

RULES

Generated from booking facts + Founding Member status; contains only the artist's own booking info. A viral loop.

DATA & PII

Artist's own booking data, shared at the artist's initiative.

EVENTS

confirmation.generated.

EDGE / FAILURE

Render failure retried async; share is never on the critical booking path.

F30 Community gallery (UGC)

Moderated · `/ugc, /ugc/:id/moderate`

ACTORS

Visitor (contributes), Moderator, Public (views)

LIFECYCLE

UGC submitted (F25) → pending → [moderator] approve/hide → public gallery → withdrawable by contributor

RULES

Only approved UGC is public. Moderation guards against harmful/infringing content. Contributors can withdraw consent → item removed + CDN purged.

DATA & PII

ugc — images of identifiable people; consent + moderation + retention govern it.

EVENTS

ugc.approved / ugc.removed.

EDGE / FAILURE

Reported content is hidden pending review; takedown honoured promptly.

COMPLIANCE

DPDP (consent, rights), IP / IT Act.

Pillar 6 · Artist Management

F31 Artist registration flow + reward QR

DPDP notice+consent · `POST /auth/register`

ACTORS

Artist, System, DigiLocker (verification)

LIFECYCLE

register (fields + consent + notice) → account active + Founding Member → optional DigiLocker verify → verified (required before first payout/sale). **[RP01: artist also receives a personal QR code — scanned at Ric Platter checkout for 10% reward + sale tracking]**

RULES

At sign-up the artist is shown a DPDP-compliant notice and gives itemised consent (account vs marketing). DigiLocker identity is required before first sale/payout for provenance + KYC-grade trust. Public profile publication is consented. The personal QR is the artist's coupon — presented at the Ric Platter counter at checkout. Staff scans it and enters the bill total. System applies 10% off and logs the bill amount as an attributed sale linked to the artist's active booking. One redemption per booking, time-boxed.

DATA & PII

users/artists — name, email, phone, city, medium, bio = personal data. Full DPDP lifecycle applies. perk_redemptions {id, principal_type, principal_id, bill_amount, discount_amount, artwork_ref, visit_ref, redeemed_at}.

EVENTS

artist.registered, artist.verified. perk.redeemed → sale attributed + ledger entry.

EDGE / FAILURE

Duplicate email/phone guarded; unverified artists can exhibit but not receive payouts; consent withdrawal triggers the erasure workflow.

COMPLIANCE

DPDP (notice, consent, rights, retention).

F32 Post-exhibition feedback survey

ACTORS

Artist, System

LIFECYCLE

exhibition ends → survey invite → artist submits rating/NPS/notes → feeds improvement loop + satisfaction metric

RULES

Voluntary; tied to a completed booking. Free-text is treated as potentially personal and stored under the same retention rules.

DATA & PII

feedback linked to booking/artist; free-text may contain personal data.

EVENTS

feedback.submitted → satisfaction/NPS aggregation.

EDGE / FAILURE

One response per booking; reminders capped to avoid nuisance.

COMPLIANCE

DPDP (personal data).

4 Configurability Changes

These changes are already reflected inline in the feature blocks above. This section documents the rationale and data model additions.

C01 Slots fully variable & editable

The wall is not a fixed board. Admin can add, remove, resize and reposition any slot at will; layouts save as reusable templates; only slots with a live/booked artwork are locked during a re-config. Every structural edit is versioned and written to `audit_log`. Extends F01/F02; no change to booking or payment path.

C02 Slot sizes configurable

Sizes are a managed catalog, not a hard-coded S/M/L/XL enum. Admin defines each class as a catalog row: name, physical dimensions (W×H cm), weight limit and editable base price/day. Add, rename, retire classes; changes apply to future bookings only. A confirmed booking keeps the price it was quoted.

New table: `size_catalog` {id, name, w_cm, h_cm, weight_kg, base_price, active}

C03 Add-on pricing editable (incl. coffee)

Add-ons become an admin-managed catalog with editable prices and availability. Coffee add-ons for the Ric Platter partnership live in this same catalog under a 'coffee' category. A booking locks the add-on price at purchase time.

New table: `addon_catalog` {id, label, price, applies_to, category, active}

C04 Full admin queue management

Admin can reorder, promote/demote, remove, add notes, override priority, and force-match any waitlisted artist directly to an opening slot — all actions audited. Manual overrides sit above the automatic priority rule.

New table: `queue_overrides` {waitlist_id, action, actor, note, at}

C05 Admin-set refund policy (single line)

Refund rules are a single admin-configured line: the admin sets one refund percentage, and it applies uniformly to all cancellations. No complex tier logic, no per-type overrides. The refund engine reads this one value. The policy version in force at booking time governs that booking's refund; the agreement (F20) embeds it.

New table: `refund_policy` {percentage, version, updated_by, updated_at}

C06 QR-only — NFC removed entirely

NFC is dropped. QR is the single scan mechanism across the wall — cheaper, simpler, no tag inventory, no tap-hardware dependence, works on any phone camera. Check-in (F15) links the artwork to a QR; scan tracking (F21) counts QR scans; artwork pages (F22) are reached by QR.

Mitigation for the loss of NFC's tamper-proof crypto:

- Resolve every QR through a signed server-side redirect (short branded URL → signed token → artwork page).
- Tamper-evident, branded QR labels plus a staff spot-check line on the checklist (F14/F15).

Removed: NFC tag inventory table, NFC-linking columns on checkins, NFC add-on line-item.

C07 Minimal revenue & expenditure ledger

A simple two-list ledger replaces the auto-generated P&L; engine. Record revenue entries (bookings, add-ons, coffee, sale commission) and expenditure entries (venue share, ops, misc) with a category tag and date; show a running monthly summary; one-click CSV export for the accountant. GST invoices are still issued on transactions (unchanged). Integrate Tally/Zoho Books when volume justifies it.

New table: ledger {id, type(revenue|expense), category, amount, note, date, source_ref}

5 Ric Platter Partnership — QR Coupon Reward + Sale Tracking

The wall lives inside a restaurant. Instead of a full menu-integration and food-ordering system, the partnership is a simple, elegant QR coupon reward with built-in sale tracking: artists and visitors get a personal QR code when they register, and they scan it at the Ric Platter counter while checking out. The scan applies 10% off their food bill AND captures the bill amount — giving Artwall a clean record of every rupee of restaurant revenue the art wall drives, without touching Platter's POS or billing.

RP01 QR coupon reward + sale tracking

ACTORS

Artist, Visitor, Ric Platter staff (scans QR at counter + enters bill amount), System

LIFECYCLE

Artist registers (F31) or visitor registers (F26) → receives a personal QR code → eats/drinks at Ric Platter during active booking/visit → **at checkout, presents QR at the counter** → Platter staff scans it → scan page prompts staff to enter the bill total → system validates eligibility → 10% discount computed and shown → **bill amount + discount + attribution (which artwork/visit drove the footfall) logged as a sale record** → Platter applies the discount on their bill

RULES

- 10% off the food bill (admin-configurable rate).
- Eligibility: artist = active booking; visitor = registered/scanned artwork during current visit.
- One redemption per visit/booking, time-boxed (e.g. same day).
- No stacking unless admin opts in.
- Who bears the discount cost (Artwall, Platter, or split) is defined in the partnership agreement.
- Ric Platter handles billing — Artwall does NOT collect payment for food. No e-commerce operator implications.
- **Sale tracking:** the bill amount entered at scan time is the single data point that powers the entire attribution story. No POS integration needed — the scan IS the sale signal.

DATA

perk_redemptions {id, principal_type, principal_id, bill_amount, discount_amount, artwork_ref, visit_ref, redeemed_at}. The bill_amount field is what makes this a sale tracker, not just a coupon log.

EVENTS

perk.redeemed → sale attributed → ledger entry (C07) → partnership dashboard updated.

EDGE / FAILURE

Expired/over-cap redemptions rejected cleanly with a friendly message. QR validation requires connectivity; offline fallback is manual staff discretion with post-hoc reconciliation. Bill amount field is required and validated (positive number); if Platter staff skips it, the discount still shows but the record is flagged for reconciliation.

What the scan captures

- **Who:** artist or visitor (pseudonymous principal_id from the QR).
- **What drove them:** artwork_ref or visit session — the art that brought the footfall.
- **How much they spent:** bill_amount entered by Platter staff at checkout.
- **Discount given:** computed from the bill and the admin-set rate.
- **When:** timestamp of the scan.

This gives Artwall a clean, defensible dataset: total restaurant revenue attributed to the wall, per artwork, per day — the proof that art drives footfall and spend. No POS sync, no menu integration, no payment collection. Just one QR scan at checkout.

What is NOT in scope

- No restaurant menu catalog in the WMS (P01 removed).
- No food ordering through the platform (P02 removed).
- No complex revenue-share ledger or split-settlement (P03 removed — sale tracking via QR scan replaces it).
- Ric Platter bills food directly — Artwall is not an e-commerce operator for food.

Partnership contract requirements

- A written agreement between Artwall Labs and Ric Platter must fix: the discount rate, who bears the cost, redemption rules, reconciliation cadence, data-sharing scope (pseudonymous tokens, not raw customer identity), and term/exit.
- Sale tracking terms: Platter staff entering the bill amount at scan time is a condition of the partnership — both parties get a shared dashboard showing attributed revenue. Artwall shares aggregate sale data with Platter (total attributed, per-day) but not individual visitor/artist identities.
- Coffee add-ons sold through the WMS (C03) are Artwall's own line-items, not Platter's — they are priced and invoiced by Artwall with GST.

Compliance

- No GST e-commerce operator treatment — Artwall does not collect or split food payments.
- Food safety (FSSAI) is entirely Ric Platter's responsibility; Artwall does not sell or handle food.
- DPDP: the QR coupon links to a registered visitor/artist — personal data scope is already covered by F26/F31 consent.
- Consumer protection: food refunds/quality are Platter's responsibility, clearly communicated to the visitor/artist.

6 Production-Grade Engineering

6.1 Environments & release

Concern	Standard
Environments	local → staging (prod-like, seeded) → production; no shared DBs across envs
CI	lint + typecheck + unit + integration on every PR; block on red; secret-scan
CD	trunk-based, tagged releases, blue-green or rolling deploy, one-command rollback
Migrations	versioned, forward-only, reviewed; expand-then-contract for zero-downtime schema change
Config/secrets	12-factor env config; secrets in a manager (not in code/bundle)
Feature flags	risky features (force-release, takeover, payouts) behind flags for staged rollout

6.2 Reliability & scale (to 10,000 users)

- Stateless API behind a load balancer; scale pods horizontally — no server-side session affinity.
- Data tier: Postgres primary + read replica, PgBouncer pooling; Redis for cache/sessions/rate-limits; queue workers scale independently.
- Idempotency on all money and booking writes (order ids, webhook event ids) to survive retries.
- Backups & DR: automated daily backups + point-in-time recovery; documented restore drill; defined RPO/RTO.
- Graceful degradation: search index and emails are off the critical path — the wall keeps booking if any is down.

6.3 Observability

- Structured logs with correlation ids across API → queue → webhook; no PII in logs.
- Metrics & SLOs: availability, booking success rate, payment-webhook lag, scan-ingest lag; alert on burn.
- Tracing on the booking→payment→confirmation path; audit_log for every override and money movement.
- Error tracking with release tagging so regressions are tied to a deploy.

6.4 Testing quality gates

Layer	What it proves
Unit	Pricing engine, state-machine transitions, validators correct in isolation
Integration	Booking↔payment↔agreement flow, webhook verification, refund math
Concurrency	No double-book under 50 parallel bookings on one slot
Security	IDOR suite, authz on every write, upload validation, injection/XSS
Accessibility	Keyboard-only + screen-reader pass; WCAG 2.1 AA
E2E	Golden paths per role (visitor scan→share, artist book→sign, admin check-in→live)

7 Security Engineering & Threat Model

Asset	Primary threat	Control
Admin actions	Privilege escalation	Server-side authorize(), default-deny, audited overrides
Slot inventory	Double-booking race	Advisory lock + reservation hold + unique constraint
Money	Forged 'paid' confirmation	HMAC-verified webhook only; idempotent; no client-trust
Artist data	IDOR across accounts	Ownership checks on every own-scoped route
Uploads	Malware / disguised files	Presigned S3, MIME+magic-byte, size cap, re-encode
Inputs	SQLi / XSS	Parameterised queries, boundary validation (Zod), output escaping, CSP
Signals	Scan/reaction spam	Rate-limit per IP+cookie, dedupe, bot detection
Secrets	Leak via client/logs	Secrets manager, none in bundle, no PII in logs
Sessions	Token theft	httpOnly+Secure cookies, short TTL, Redis denylist, 2FA staff/admin

Security is continuous: dependency scanning, periodic penetration testing before major launches, and a documented incident-response runbook that plugs directly into the DPDP breach-notification workflow.

8 DPDP Act 2023 & Rules 2025 Compliance

India's Digital Personal Data Protection Act, 2023 received assent on 11 August 2023; the DPDP Rules, 2025 were notified on 13–14 November 2025. The substantive compliance deadline is 13 May 2027. Artwall Labs processes personal data of identifiable artists and visitors and is a Data Fiduciary.

8.1 Roles & scope

DPDP concept	In the WMS
Data Fiduciary	Artwall Labs Pvt Ltd — decides purpose & means of processing
Data Principal	Artists (F31), walk-in visitors (F26), waitlist entrants (F10), UGC contributors (F25)
Data Processor	Sub-processors: Razorpay, cloud/storage, email/WhatsApp, search, analytics
Personal data held	Name, email, phone, city, bio, booking history, selfies (UGC), feedback text
Not stored by us	Card/PAN data (Razorpay-scoped, PCI); raw IP against scans (minimised)

8.2 Notice & consent

- Consent must be free, specific, informed, unconditional and unambiguous — collected at each point of collection (F26, F31, F25, F10).
- A plain-language notice accompanies every consent: what data, why, for how long, which rights, and how to withdraw.
- Purpose limitation & no bundling: account/booking consent is separate from marketing consent.
- Withdrawal is as easy as giving consent — a one-tap control; withdrawal stops further processing and triggers deletion.
- A Consent Manager record ties every processing activity to the consent that authorises it.

8.3 Data Principal rights

Right	How the WMS serves it
Access & summary	Self-service export from dashboard
Correction	Editable profile fields; correction request workflow
Erasure	'Delete my data' flow → erase or anonymise, except legally required records
Grievance redressal	In-product grievance channel with time-bound response
Nominate	Ability to nominate another to exercise rights
Withdraw consent	One-tap withdrawal per purpose

8.4 Children's data

The DPDP Act treats anyone under 18 as a child and requires verifiable parental/guardian consent. It prohibits tracking, behavioural monitoring and targeted advertising directed at children. Registration (F31), walk-in (F26) and especially selfie UGC (F25) must handle the possibility of a minor: age self-declaration + a parental-consent path; no behavioural profiling of visitors regardless of age.

8.5 Security safeguards & processors

- 'Reasonable security safeguards' are a statutory duty — encryption in transit and at rest, access control, and the full Section 7 control set.
- Every Data Processor is bound by a written data-processing agreement restricting them to our instructions.
- Privacy-by-design: EXIF stripped on upload (F09), no raw IP on scans (F21), signed tokens not PII in QR (F15), artist contact never exposed (F22).

8.6 Breach notification

On a personal-data breach, the WMS incident runbook notifies the Data Protection Board and affected Data Principals without undue delay. Detection is automated (Section 6 observability); an incident-response team, escalation path and comms templates are pre-staged.

8.7 Significant Data Fiduciary (forward-looking)

If the Board classifies Artwall Labs as a Significant Data Fiduciary, additional duties attach: DPO based in India, periodic DPIA, and independent audits. The architecture (audit_log, consent records, retention schedule) is built so these become reporting exercises, not re-engineering.

Penalties for non-compliance run up to ₹250 crore for failure to take reasonable security safeguards.

9 Other Regulatory Compliance

9.1 GST & tax

- GST-compliant tax invoices auto-generated on every booking/add-on under GSTIN 08ABFCA1595D1ZR, with correct HSN/SAC, place of supply and tax split.
- Output tax tracked in the ledger (F18); TDS/TCS handled on artist payouts where applicable.
- Coffee add-ons sold by Artwall are invoiced with GST. Food at Ric Platter is billed by Platter — no e-commerce operator treatment for Artwall.

9.2 IT Act, 2000 — e-signature & intermediary

- The exhibition agreement (F20) is e-signed; electronic records and signatures are legally valid under the IT Act, with hash-sealed evidentiary integrity.
- As a platform hosting UGC and artist uploads, Artwall follows intermediary due-diligence norms: clear terms, grievance officer, prompt takedown.

9.3 Payments — RBI & PCI (via Razorpay)

- Razorpay is the PCI-DSS-scoped payment aggregator; the WMS never stores card/PAN data.
- Card-on-file tokenisation per RBI norms is handled by the PSP; we hold only tokens/refs.
- Refunds follow the admin-set policy (C05) and are reflected in the agreement (F20).

9.4 Consumer protection & e-commerce

- Transparent pricing: all fees + GST shown before pay. Clear cancellation/refund terms in the agreement.
- No dark patterns: consent and marketing opt-ins are unbundled and reversible.
- Food quality/refunds are Ric Platter's responsibility, clearly communicated.

9.5 Intellectual property

- Artists retain copyright; the agreement (F20) grants Artwall a limited display/marketing licence — never an assignment.
- UGC screened at moderation for infringing material; notice-and-takedown path handles claims.
- Resale royalty (4% artist + 1% platform) enforced via ERC-2981 on Polygon as a contractual entitlement.

9.6 Accessibility

Public surfaces target WCAG 2.1 AA — keyboard operability, contrast, alt text and reduced-motion are quality gates. Consistent with the Rights of Persons with Disabilities Act, 2016 and GIGW guidance.

10 Feature × Compliance Traceability

Which regulated obligation each personal-data or money-touching feature triggers. Features that touch only non-personal config are omitted.

Feature	DPDP	RBI/PCI	GST/tax	IP/IT Act
F07 Multi-slot booking	✓	✓		
F09 Artwork upload	✓			✓
F10 Waitlist	✓			
F17 Razorpay payments	✓	✓	✓	
F18 Ledger			✓	
F20 Agreement	✓	✓	✓	✓
F21 QR scan tracking	✓			
F22 Artwork page	✓			✓
F25 Selfie UGC	✓			✓
F26 Walk-in + reward QR	✓			
F30 Community gallery	✓			✓
F31 Artist reg + reward QR	✓			
F32 Feedback	✓			
RP01 QR coupon reward	✓			

F20 (the agreement) is the densest node — it is simultaneously a personal-data record, a payment term, a tax document and an IP licence.

11 Data Retention & Lifecycle Schedule

DPDP requires that personal data not be kept past its purpose. Retention is defined per data class, balancing the Act's minimisation duty against tax/contract record-keeping law.

Data class	Retain while / for	On expiry or withdrawal
Artist account/profile	Account active + purpose valid	Erase or anonymise on closure (keep tax/contract records)
Booking & agreement	Statutory contract/tax retention	Retain minimally for legal record
Payment records	As required by tax/PSP/RBI	Retain per law; card data never held by us
Walk-in visitor	Until purpose served / consent window	Delete on expiry or withdrawal (F26)
Waitlist	Until matched or entrant leaves	Delete on exit or withdrawal (F10)
Selfie / UGC	While consent stands & item is public	Delete + CDN purge on withdrawal (F25/F30)
Scan/reaction signals	Aggregated; raw events short-lived	Aggregates kept (non-personal); raw rolled off
Feedback text	With the related booking record	Rolled off with booking's retention window
Perk redemptions + sale log	Partnership reporting, sale attribution + reconciliation	Anonymise principal after reconciliation; keep aggregates
Audit log	Long-lived for security/accountability	Append-only; access-controlled; not repurposed

This specification is a living document. Regulatory positions — especially the phased DPDP Rules timelines up to 13 May 2027 — should be reviewed with counsel before launch and re-checked each quarter. References: AWL/PRODUCT/2026/WMS-001 (feature plan), AWL/ENG/2026/WMS-AUDIT-001 (audit pack).